

Session 1

Cyber Security Fundamentals

Table of Contents

What We Will Cover	3
Cyber Security: The What, The Why, And The How	4
Why Are Intruders Doing This?	7
What Do We Mean By Data?	7
Some High Profile Cyber Security Cases	8
How Is Cyber Security Managed Across and Within Countries?	13
Cyberspace	14
Some of the Laws Related to Cyber Security	15
Definitions Around Law in Cyber Security	16
3Ps: Policy, Process, and Procedure	17
International Performance on Cyber Security	19
The Critical Stages of Cyber Security	21
Identify	22
Protect	23
Detection	23
Respond	24
Recovery	25
Summary	26

What We Will Cover

In this session, we'll be exploring three areas. These are:

1. An introduction to cyber security, including high profile cases of security breaches.
2. How cyber security is managed across and within countries.
3. Key phases of cyber security over time.

By covering these three topics, you will be making progress against two of the module's learning outcomes. They are:

LO1: Demonstrate the procedures and controls necessary to maintain the security of an organisation.

LO2: Explain the need for, purpose of, and key elements to a range of cyber security policies, procedures, standards, and guidelines.

Cyber Security: The What, The Why, And The How

What is Cyber Security?

The Information Revolution started with computers. But over time we've begun to digitally communicate with one another using different means, and the term 'device' has become common:

- Mobile phones.
- Games consoles.
- Wearable tech.
- EV Chargers and other home devices.



Can you think of any more?

What do all these different devices have in common?

They have to be connected in some way, to one or typically multiple other devices. And we refer to that connection as a network.

That's how we explain the word 'cyber', but where does the security aspect come in?

In an ideal, crime-free world, we'd all be connected to each other through the devices in our own network. For example, using your mobile phone to turn your EV charger on whilst at work, or to friends, family, and colleagues that we're happy and trust to be connected to.

Unfortunately, there is financial, and even malicious gain to be had from people not in your trust circle, from falsely or otherwise, gaining access to your network.

This leads us to our first definition...



Cyber Security is ... the task of identifying, managing, and wherever possible eliminating, the risk of individuals and/or organisations (knowingly or unknowingly) accessing your network against your will.

We've added the words "knowingly or unknowingly" in there because cyber intrusion doesn't always go ahead unnoticed.

To substantiate that point, research in 2022 by the US Department of Justice claimed that only one in seven cyber-crimes are reported, which means a **staggering 85% or more** of cybercrime can be left hidden or exist totally unnoticed in an organisation.

We've used the word 'risk' because that, in many ways, defines what cyber security is all about. It's about prevention rather than cure. Once an attack has taken place, the main tasks at hand are sealing the attack and attempting to mitigate the damage done.

Preventing it from taking place in the first place: that's what cyber security really aims to achieve.



Covid-19 is a great example. In this decade, the entire world has been through a global pandemic, and it's affected us in different ways: Financial. Health damage, both physical and mental being just two.



Social interaction and computer networks have a lot more in common than we might imagine.



Going back to those initial months, when the entire world was trying to manage the outbreak - what were we told to do?

Isolate.

Countries all around the world introduced lockdowns. We were forbidden from either leaving our homes or going within two metres of another person unless they were in our household. The idea being that if you are alone in a room, in your home, totally unconnected from the outside world, then you are not at risk of catching and subsequently spreading the virus. Note that word risk again.

The world of cyber is no different. **Any device is at risk of attack if it's connected to any network**, and the risk becomes even greater if it's connected to the internet. Large companies, medium-scale companies, even small companies, are at risk if they are connected to a network.

2021: 2,000+ data breaches occurred in the U.S. alone, all of which were high profile.

Attacks include, but are not limited to, the financial, healthcare and retail sectors.



Fast forward to 2023, and the number of attacks is getting bigger, not smaller. In pandemic terms, we're still in the growth phase, not the recovery.



In the past, large companies were the primary target. More recently, smaller companies are increasingly being targeted. In 2021, around 2,000 data breaches occurred in the U.S. alone, all of which were high profile. And the attacks weren't limited to the financial sector as you might expect. Attacks also took place in healthcare, retail, pretty much all sectors. And they've impacted millions of people around the world each year. In fact, the number of attacks is getting bigger, not smaller. In pandemic terms, we're still in the growth phase, not the recovery.

Let's now consider the why....

Why Are Intruders Doing This?

This isn't a trick question. It is mainly for financial gain. The data companies large and small hold has value, and that data, once collected, can be sold, and used directly for financial gain – typically by gaining access to other's people money.

But that is not the only reason. Rather than directly take money from individual bank accounts, intruders may elect to hold the company they stole the money from to ransom. Pay up, in return for your data. That's where the term 'Ransomware' comes from.

Others choose to do it to expose the companies. Many of these are on a moral crusade, for example against political idioms such as capitalism.

Just as joyriders steal cars for the high of taking and driving the car before disposing of it, some cyber intruders do it for the fun of it or because they want to be 'famous' for bringing down a large corporate entity who they perhaps have little respect for.

Then of course, we have the dark web. Some data is taken for gain that is neither financial, nor infamy, but simply to satisfy a need or desire in themselves or others.

What Do We Mean By Data?

You might be thinking letters and numbers. Bank account digits perhaps. Names and addresses of customers. Emails written from presidents or prime ministers. And these would all be correct. Except, remember in this digital world that digits can be used to form images. And moving images are simply video.

So what do all these have in common?

When criminals steal your data, or abuse your image, make false video recordings, whatever, what they are really doing is taking a part of you. They are stealing your...Identity.

And that's why cyber-crime can touch people's emotions, as much as harm their bank balance. Which is why so much of cyber security is also about psychology.

Some High Profile Cyber Security Cases

This section will provide some context around cyber-crime. The best way to do this is to consider some of the numerous incidents that have occurred over recent years, resulting in literally billions of user records being compromised.

Let's not forget that whilst these are the ones that made headline news, they shouldn't be mistaken, nor allow us to disregard, the countless other cases of small companies or individuals that fail to be newsworthy.



Even if you're not old enough to remember when Yahoo was actually a big deal, hopefully you know the name?

The data breach of Yahoo still ranks as one of the most devastating cyber-attacks, because it affected a significant number of people, and it took place really before many of us truly understood this whole cyber security thing.

The first attack took place in 2013, but the attacks continued until 2016. The intruders were Russian hackers who targeted cookies of records and backups, which they stole online with the help of backdoors.

The records stolen comprised of personally identifiable information (PII) such as email addresses, phone numbers, names, birth dates, calendars, passwords, and their security questions. Yahoo stated in their report that around 1 billion accounts were stolen, yet when Verizon bought the company in 2017, they announced the total number of records stolen was nearer 3 billion. In one instance, Yahoo's failure to report the issue resulted in a fine of \$35 million, and they faced around 41-action lawsuits.



Even the biggest and oldest are susceptible to attack. This involved a sweeping attack on the MS Exchange servers, which in fact is the most significant email server in the world. The hackers exploited the four zero-day vulnerabilities, which allowed them to gain unauthorised access to



British Qualifications
in Skills and Leadership

Let's Reinvent Education Together.

emails from local governments and small to large businesses. Around 30,000 US companies and about 60,000 companies worldwide were affected by the attack. The hackers took advantage of some coding errors for about three months, breaking into various companies' email servers.

The requirement for the attacks was simply an internet connection and on-premises, locally managed systems. On gaining access, they were able to inject malware and use backdoors for accessing other media, until finally taking hold of the servers. They finally conducted masquerading, which we'll discuss in a later session.

As stated earlier, once an attack has taken place, the only solution is then recovery. Recovery in this case involved Microsoft patching the mistake, and the companies involved updating their servers. Patching is a term we'll discuss later in the unit. Unfortunately, since the system was not on the cloud, Microsoft could not immediately push the patch to fix the issues.

In July 2021, the Biden administration along with the FBI, accused China of this, and Microsoft named Hafnium as the culprit for the attack.



Number three on our list is First American Financial Corporation.

This attack took place in May 2019 and impacted around 885 million file records which were leaked. It occurred due to poor data security measures and issues in the website design. The company labelled it as a data leak rather than a breach. However, the website design error, known as the insecure direct object reference (IDOR) enabled access to private information which got into the wrong hands without any authentication procedures. This meant anybody with the link to the documents could look at them without any stoppages.

A further error by the company was logging the records in sequential order, which meant the only requirement to view subsequent customer records was simply to change the number in the URL.

Around 1 billion accounts were exposed, however, no data was exploited or compromised. Nevertheless, details like bank account numbers, bank statements, driver's licenses, wire transfer receipts with social security numbers, and mortgage payment documents were stolen. Since the company violated the cybersecurity laws by ignoring the red flags in 2018 and other administrative errors, they were fined roughly \$500,000 by the SEC. SEC stands for the Security and exchange commission by the way.



Facebook's major case happened in April 2021 and around 530 million users were exposed. It was one of the biggest known leaks with the names, accounts, phone numbers, and passwords of approximately 530 million people going public. The problem was in the platform's tool that synced the contacts, and the hackers exploited these vulnerabilities by scraping the user profiles to obtain the customer data.

Facebook claimed no data was compromised since the information only got into the public domain for a short period. Nevertheless, hackers and scammers were able to take advantage of innocent users through their emails, phone numbers, and names.

Since as far back as 2013, Facebook had faced many similar data breaches. In March 2019, information aired that Facebook employees had access to around 0.6 billion users. In addition, the account IDs and passwords of Instagram and Facebook were on the plaintext files. Though Facebook claims that no sensitive information leaked, hackers were again able to take advantage of a security weakness.

In April 2019, UpGuard found that 540 million unsecured Facebook user data records were stored on public AWS S3 cloud servers. In addition, the media company from Mexico and third-party app developers could not password-protect their datasets, leaving information vulnerable, accessible, and downloadable.

Whilst Facebook itself was not the direct culprit, the scrutiny challenged how the social network could make this data accessible to a third party. Finally, Facebook was forced to audit their third-party developers. As a result, more restrictions were levied upon them.

Fast forward a few months, more records were found on the dark web, and a hacker group from Vietnam misused the Facebook API and scraped the site to get access to the phone numbers, names, and user IDs of more than 300 million users. We'll what what we mean by the term 'scraping' in a subsequent session.



Next is the unfortunate case of Facebook & Cambridge Analytica. This case made headline news around the world. It happened in April 2018, and around 50-90 million user accounts were compromised. Cambridge Analytica, a UK-based consulting company, stole and traded about 50-90 million user Facebook accounts. This was one of the most high-profile cyber security attacks.

Aleksandr Kogan exploited a loophole from the third-party quiz app to access the data. The loophole in the Facebook API enabled Kogan to collect data from anyone who downloaded the app, and their Facebook friends circle were also compromised.

This was not directly Facebook's error since Cambridge Analytica violated Facebook's terms and conditions.

However, they kept selling the data without Facebook's users consent as no rule stopped them from doing that. Facebook knew about the issue since 2015, but only acted once the Analytica employee Christopher Wylie blew the whistle.

When the U.S.'s Federal Trade Commission (FTC) learned about the incident, they levied a fine of \$5 billion on Facebook as they were found to have continuously violated their data security policy and had in place poor procedures around data security. The FTC also demanded a complete restructure to increase compliance for privacy. The FTC filed a further lawsuit against Alexander Nix, the CEO of Cambridge Analytica, who subsequently resigned.



A LinkedIn attack took place in April 2021 and impacted around 0.7 billion user records. The hackers posted the identity of 93% of the user base, which they found through data scraping LinkedIn's website. Most of the information was made available publicly. The data scraping with the LinkedIn API violated its terms and conditions.

The scraped data included full names, email addresses, phone numbers, genders, geolocation records, usernames, and social media account details. The exposed email address helped the hackers conduct crimes like Ransomware and Phishing attacks. This data was publicly available

despite an information security concern over third parties while they created the OSINT databases. (OSINT stands for open-source intelligence).

The hackers were able to target high-profile company employees and individuals. A lot of money was therefore placed at risk.

JPMORGAN CHASE & CO.

This occurred in June 2014 and impacted most of JP Morgan's customer base. With JPM Chase being among the largest banks in the US, this translated to 76 million individuals accounts, and 7 million small business accounts being compromised.

At the start, it was assumed to be affecting only one million accounts. However, the investigation established a much greater impact. The attack lasted from June to July. No financial fraud was recorded since the stolen identities included only names, phone numbers, and emails. Investigations confirmed that the hackers breached the bank's servers through employees' identities, resulting in multiple gigabytes of data coming into the hands of the Russian hackers. From that point on, JPM Chase has spent over \$250 million annually to secure its data. EOS 26



Finally, we come to Home Depot - a renowned North American home improvement store. Their attack took place in April 2014, impacting around 56 million payment card numbers and 53 million email addresses. The attack was through manufactured malware and took place over more than five months. By the time it had been detected and finally removed, millions of customers from the US and Canada were affected.

Cybercriminals most likely made this attack through a third-party supplier. They were able to enter the network, install the malware on POS systems, which allowed them to collect the payment card data, and then upload them onto a separate server.

The attack evidenced that even large retailers were needing to spend on cyber security to protect sensitive information. And spend they did. By 2020, Home Depot had radically overhauled and enhanced its payment system for protection reasons. Nevertheless, they lost \$180 million in damages, mainly from payments to credit card companies, banks, customers, and court settlements.



We've shared several cases with you for two reasons. Firstly, many of these cases mark watershed moments in the sectors those organisations work in. Secondly, do you have any idea of what a recurring theme across most of the examples is?

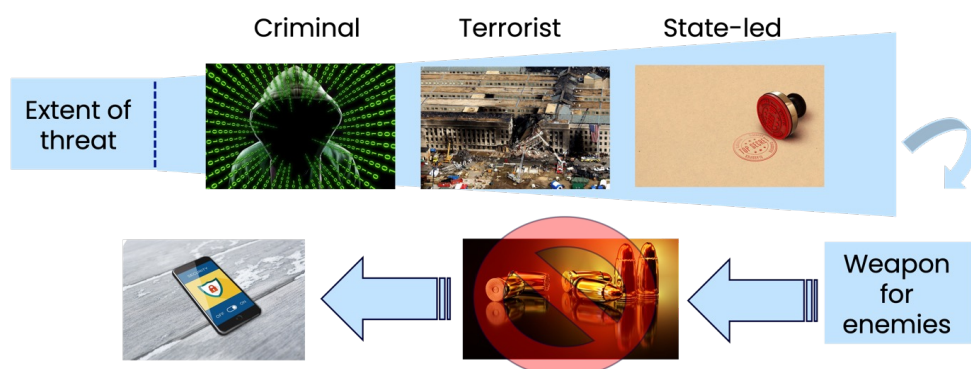
A recurring theme is it was often through third parties violating the terms and conditions of the parent company. Facebook in particular has suffered a lot from such third-party breaches. This means it is seldom one company alone that is responsible - cyber security attacks, and indeed their resolution, often requires a combined effort.

Finally, let's consider the financial implication of all this. JPMorgan has been spending \$250 million each year on cyber security since 2014. Imagine how much Facebook, Microsoft, Google, and Apple will have been paying. Cyber security is now a trillion-dollar industry. Such responsibility brings with it considerable stress, but also high salaries. Senior management teams are willing to spend high sums on able cybersecurity technicians, analysts, scientists, engineers, etc, even though the value they add to the business is purely risk management rather than increased turnover.

How Is Cyber Security Managed Across and Within Countries?

This is typically now a government level problem, so within that discussion, we'll be asking how effective individual countries are being, and how this effectiveness is being measured.

On a country level, threats can take place broadly on three levels. What we tend to think of in society, and what we've mainly been discussing so far, are criminal attacks. Malicious individuals, or small groups of individuals. We also need to be thinking about cyber-security as a terrorist threat. And then some areas of government will even be preparing against and actively managing state-led attacks. In other words, one country attacking another, because cyber-security is now a weapon of war. We're talking about state-led attacks from the militaries of enemy countries.



Cyber-attacks are now a new weapon for enemies, which they use significantly. Mobile phones are the modern day bullets. And this is a great concern across all governments. Whilst governments worldwide are finding cyberspace to be one of the prime sources of economic activity for its people, they are now increasingly prone to cyber-attacks from malicious insiders and outsiders from their own hierarchies.

Cyberspace

Now let's talk cyberspace. Remember from our earlier discussion, cyber is now the entire cyberspace. It's not computers alone any longer. When we talk of Web 3.0, when we talk of the Metaverse, we are talking cyberspace, which in turn means cybersecurity.

Cyberspace is now the most significant economic market in the world. With bricks and mortar-based operations reducing and, in some cases, ceasing to exist and diminishing to simply warehouses, everything else will be in cyberspace.

Governments understand this and are acting on it. Whether that is the National Security Strategy of the U.K., the U.S., the E.U., or other corners of the world, they will all be developing clauses, policies, and legislation for cyber security. Governments now have national-level cyber security agencies and developed countries will even have local cyber security agencies, particularly around their capital cities.

Developing nations also have a significant role in cyber security, particularly when you consider they are often the locations from which cyber threats emerge. When discussing location parameters for cyber-attacks, the terminals in developing countries are at the top.



What does this mean?

A. Before the evolution of cyberspace, one country would be aware of another countries laws in order to ascertain its degree of threat it poses. When a country chose a course of action which contravened its own (or internationally accepted) laws, it's regarded as being in breach, which may have resulted in escalation of conflict, either physically or diplomatically. A good example of this in diplomatic terms is where two neighbouring countries with shorelines, who share the same sea or ocean, have laws around fishing. Such laws might define where each are permitted

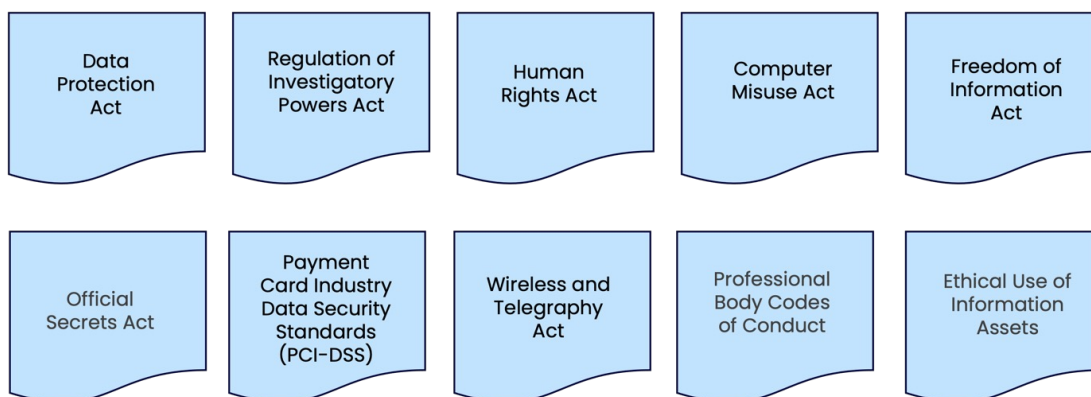
to fish, or it might state the volume of fish stocks they are permitted to take from the sea. If one country subsequently breaks its law by fishing in waters it's not permitted to do, or fishing a higher volume, then this would be termed a diplomatic breach. These are offline laws.

Nowadays, countries can exert the same level of scrutiny on their online laws. So, if a country has concerns over how another country is legislating for its online activities, this may result in a stand-off, which may escalate to a full-scale diplomatic conflict. A good example of this are the ongoing disputes both the U.S. and the U.K. have with China.

Various online laws have been formulated. And whilst governments typically develop their own policies, guidelines, standards, and procedures, they'll also be acutely aware of other governments' policies too.

Some of the Laws Related to Cyber Security

Here are some common ones in place in the U.K. Whilst some are fairly obvious in how they're related to cyberspace, others are less so.



- The **Data Protection Act** describes how a country or organisation will protect its sensitive data.
- The **Regulation of Investigatory Powers Act** formulates how an investigation can be conducted in the case of any cybercrime, and to what extent.
- The **Human Rights Act**. On first glance this might appear to be unrelated to cyberspace. But what if the police suspect an individual of being involved in a cyber related crime? In many countries the courts do not grant third-degree rights to the police so quickly, and only do that if solid evidence against the convict has been found. This is on the basis of their human rights. So, in fact, this may have direct consequences.

- The **Computer Misuse Act**. This law was first introduced as far back as 1990, and was actually in response to one of the earliest cases of cybercrime. This was back in the day when people were still using dial-up modems. Two individuals by the name of Schifreen and Gold gained access to British Telecom's Prestel database. Amongst other things, the pair were even able to gain access to the inbox of a prominent member of Britain's Royal Family. How did they do it? Well, in fact they gave rise to the trick of 'shoulder surfing'. They glanced over the shoulder of a Prestel engineer as he was entering his username and password.
- The **Ethical Use of Information Act** limits the use or action individuals may make with information on another. A good example of this are images of a person of a sexual or malicious nature. Such an act would prevent those images being shared in cyberspace.
- The **Wireless and Telegraphy Act** protects against crimes through smartphones, wi-fi, and whatever comes under the wireless domain.
- The PCI-DSS protects against the misuse of credit cards and hence against financial fraud.

Definitions Around Law in Cyber Security

There are some standard definitions you should be aware of concerning the role of government in maintaining cyber security. Firstly, the difference between guidelines and laws.

Parliament (or Congress in some countries) represent the elected politicians who debate and legislate for various public issues of varied levels of importance. They form the legislation, or the **laws**, which every person must comply with.

Now let's consider a public body, such as a school, or a private organisation. As bodies in their own right, they may create **guidelines** which individuals within or entering the premises of that body must adhere to. This can be its employees but can also be its visitors.

Suppose a country has a law on no-smoking in public buildings. Anyone who is found to contravene that law in any public building, has broken that law. Further, all bodies who have premises deemed to be a public space must adhere to that law whether they agree with it or not. Since the law covers all public buildings, this overrides any guidelines that body may put in place locally.

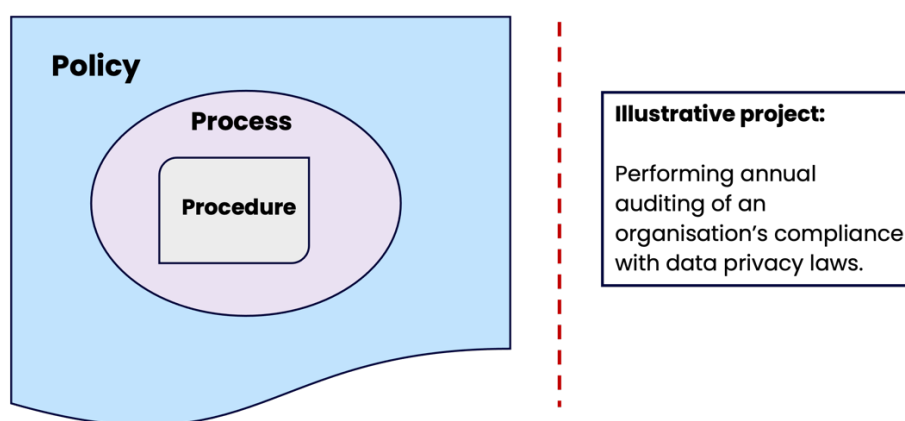
For example, suppose no such no-smoking law exists in any one country. Then a body or organisation may create its own guidelines which prohibit smoking in that building. Since no law exists, these guidelines may be put in place for those public buildings. The body (e.g. school) or organisation form these guidelines, which their members and/or visitors must follow.

Regulations are more complex laws often made of many clauses. Anyone found contravening them may be liable for punishment through the criminal court.

As a cyber security professional, it's important that you're aware of the judiciary system in which you work – and indeed may do business. So, if the company you are employed by operates in multiple countries, then their laws on cybercrime may be relevant to you just as much of those in which you are domiciled.

3Ps: Policy, Process, and Procedure

The 3Ps: Policy, Process, Procedure



- **Policy:** the blueprint on why a project is needed, and what it relates to.
- **Process:** the set of tasks needed to complete a project.
- **Procedure:** the set of instructions on how each task within a project will be completed.

A cyber security policy provides all those having responsibility within the project with a blueprint. And this blueprint will explain why it is needed, to which laws and other areas of the organisation this relates to and then it'll deal with process.

Within a policy will sit the process or processes if there are more than one. This defines the set of tasks needed to complete the project.

And then for each process will sit a set of instructions on how each task within the process must be completed. These are the procedures.

You might be asking what a project might be? One example is provided in the graphic above, around auditing the organisation's compliance. It's basically whatever action, or set of actions, is needed to alleviate, or mitigate against a cyber-attack.

As a simple example from real life, imagine a project of hosting a dinner party. The entire schedule or itinerary for the evening will be included in the brief you've assigned yourself. Let's suppose it's to have as much fun as possible around a retro theme of the 1960s. This can be considered the policy.

Then each element of the meal you will serve guests - from starter to dessert, and then onto the party games you organise, includes a list of ingredients, props, prizes etc. you need to buy. You will also need to determine timings on when to get each element started. This would be the process.

Finally, at the time of preparing the food, you will follow a recipe. At the time of the party games, you might establish some rules, depending on how serious you want the games to be. These are equivalent to the procedure.

Back to the world of cyber security, policies that describe in detail how an organisation will prevent or respond to a cyber threat, will need to be highly restricted. These policies would never be published for public consumption. Others of a less sensitive nature can be published on a website. Indeed, some organisation policies must be made openly available by law – such as an organisation's privacy policy.

Policies generally reference or adhere to the associated laws. For example, whilst it may not be a crime to breach an organisation's policy, if that policy sits under a legal act, e.g. the Data Protection Act, then breaching the policy may have violated a legal act, which may result in a criminal conviction through the court.

Irrespective of whether they have committed a criminal offence or not, policies enable organisations to discipline or terminate the employment of workers who contravene them.

Currently, specific laws on cyber security are scarce. However, there are several other acts that relate to it. Sooner or later, it's envisaged that these will be made into legal acts worldwide. Once these are in place, cyber criminals can be punished for the cyber-crimes they commit across multiple territories. This includes, for example: the hindrance of data privacy, CIA triad violation, DDOS attacks, ransomware attacks, WANNA cry attacks, DDOS attacks, SQL injection. All of these will be explained in later sessions.

International Performance on Cyber Security

There are organisations researching and reporting on performance in Cyber Security. One of the key sources for information on this is the Global Cybersecurity Index – the GCI. It's published by a research company called the International Telecommunication Union – ITU.

The link to their work is as follows: <https://www.itu.int/itu-d/sites/cybersecurity/>

Their research focuses on 82 questions around government performance in relation to their cyber security efforts. These questions fall under 5 pillars that cover legal, technical, organisational, capacity, and co-operational measures.

Five pillars:	Highest ranking nations:	Lowest performing nations:
Legal	1 United States 100	Solomon Islands
Technical	2 United Kingdom 99.54	Haiti
Organisational	2 Saudi Arabia 99.54	Dem Rep. of Congo
Capacity Development	3 Estonia 99.48	Afghanistan
Cooperative	4 Korea (Rep. of) 98.52	Dominica
	4 Singapore 98.52	Djibouti
	4 Spain 98.52	Burundi

The U.S. score highest on these measures, and they are followed by the U.K. and Saudi Arabia who are tied for second on the index. Estonia, one of Europe's leading nations around digital advancement, also score highly.

Also shown in the figure above are the countries who fall at the foot of the table. However, it should be said that countries had the right to opt-in or out of this research, and therefore these are only the countries that agreed to participate



Why is this kind of research important, and why do the U.S. rank highest?

Well firstly, ranking countries in this way incentivises governments to improve on their commitment to cyber security measures. It also provides good learning for those countries who need to improve to clearly understand what they need to improve on and benchmarks for success.

The U.S. are currently that benchmark and they score highly principally through their governing body, NIST, which we'll come onto in the next session, developing a compelling cyber security framework. They have formulated guidelines, procedures, and regulations for all categories of American businesses to fight against cyber-attacks. Cyber-attacks of 2022 instigated the Biden administration to develop a new national security strategy with cyber-attacks representing their primary concern.

The same applies to European countries including the UK, Estonia, Finland, and Denmark. They all have very stringent cybersecurity requirements for any business in cyberspace. And these are highly technical, covering emerging threats like quantum computing and various other emerging disruptive technologies. Machine Learning and Artificial Intelligence are at the forefront of attention. At the time of publishing this course, Web 2.0 vulnerabilities concern them, but these nations are now focusing more heavily on Web 3.0 vulnerabilities. As we'll cover later in this unit, Web 3.0 is effectively the metaverse.

Globalisation is one of the numerous benefits the internet has provided the world. However, it also represents one of its greatest challenges. Specifically, most of us in the developed world are able to access websites across the world with little in the way of a firewall preventing us from doing so. Therefore, whilst specific countries (e.g. the U.K.) might wish to prevent its citizens from accessing tools such as Artificial Intelligence, policing that level of access is not currently supported by national borders. In other words, if users wish to access sites that provide AI tools (in areas such as education, for example) which sit outside of the U.K., an issue emerges of where cyber laws begin and end. Specifically, does it rest with the jurisdiction of the user, or the jurisdiction of the tool owner?

The Critical Stages of Cyber Security

Definitions within the world of Cyber Security can be pretty confusing. For starters, there isn't one global body that oversees cyber security. Each region has its own body. And of course, those bodies sometimes see things differently to the others, using slightly different terminology.

Numerous cyber security governing bodies operating across regions. In fact NIST is the vendor for the ENISA. And although NCSC has its standards, the standards of NCSC and NIST are effectively the same. So each of these three bodies are very closely related.



There are generally four stages to undertaking Cyber Security:

- Assessment
- Prevent
- Monitor
- Respond

However, NIST declares five stages. These are: Identify, Protect, Detect, Respond, and Recover.



Let's consider a phishing email as an example. To deal with this eventuality, any organisation needs to go through a similar kind of process.

1. This begins with understanding what a phishing email is – which is the process of **identifying** it. All of this can be considered to take place within the process of **Assessment**, which also includes measuring the risk score of the vulnerability.
2. They would then put in place the necessary protocols and tools to protect against it. This is **Protect** according to NIST, but under the four stages of cyber security this is referred to as **Prevent**.
3. Moving forward over time, they will use this understanding and protection to **detect** when such a vulnerability has taken place. This can be manual as well as automatic through software. Again, this corresponds to **Monitor** in the four cycles.

4. Then we have what both definitions agree on – which is **Respond**. Sometimes organisations will transfer the responsibility of response to a third party.
5. The final phase of the NIST definition is the process of **recovery** from the vulnerability. In the four cycles, this would be expected to take place within the Response phase.

We'll now take a look at these four areas in turn.

Identify

At this step, our focus is on understanding the cyber security risks to the organisation's systems, capabilities, data, and assets. This is the sole purpose of Identify.

To achieve this, the Cyber Security team undertake a number of tasks. They:

1. **Identify the critical processes and assets.** Some processes need to run, even in a disaster. Support is one such process. Essential assets and operations also need identification.
2. **Identify relevant data associated with those processes and assets.** Specifically, where information comes in, where it goes out, and everything that happens to it in between.
3. **Create a policy to identify the roles and responsibilities.** The cyber security team must devise an approach to help everyone check the vulnerabilities in the processes, assets, data, and systems. The policy should be a part of the organisation's risk assessment policy list such as financial, administrative, etc.
4. **Maintain hardware and software inventory.** Software and hardware are the endpoints intruders exploit. Hence it's essential to maintain an accurate inventory covering all software and hardware.
5. **Identify threats, vulnerabilities, and risks in both the organisation's internal and external environments.** It's essential to thoroughly examine the network, infrastructure, application, and data when we talk of IT-based vulnerabilities. Apart from the seven layers of physical security, the physical layer, which includes the infrastructure, is also part of the IT sources where vulnerabilities exist.

Protect

This is really a key area of cyber security operation. We provide six likely protect activities in the table below. In some organisations there may be more than six activities.

1. Manage access to the assets	Proper authentication and authorization before access is provided to the employee or any end user. Methods include: two-factor authentication, single sign-on, multi-factor authentication, and biometric check.
2. Protect devices	Ensure proper firewall protection; Configuration changes to the device must be documented; Features not required for the workplace/mission should be deactivated; A policy for disposing of the device after it expires or gets worn out.
3. Train employees	Proper training for the employees against social engineering, phishing attacks, and all types of cyber security issues they need to know and get acquainted with. Working knowledge of the organisation's cyber security policy, its role, and their responsibilities.
4. Protect sensitive data during transit and at rest	Sensitive data must be encrypted at rest and during transit. A proper integrity check of the data undertaken at regular intervals.
5. Ensure backup	Various operating system supports automatic backup, and the cloud and software also support automatic backup.
6. Manage vulnerabilities in devices	Devices must be checked for openness with the help of vulnerability scanning tools at regular intervals.

Detection

In most organisations you will find that detection is an automated process, taking place 24x7 in the background. Nevertheless, there are still tasks for the CS expert to undertake. We cover three of these tasks, which are as follows:

- 1. Data flow**
- 2. Monitoring log files**
- 3. Calculating event impact.**

Firstly, it's about learning the **data flow** during a process:

It's important to understand how the data flows from one point to another within an organisation. That will help expose if data has been tampered with at any time. This includes ensuring that third parties and vendors understand the data flow. Whilst much of this takes place during the build and implementation of a cybersecurity project, there is still a need to monitor for irregularities through time.

Number two is pretty critical. It concerns **monitoring the log files**:

All log files must be examined using vulnerability scanning tools capable of understanding log

files. Any vulnerability identified must be reported to the relevant authority level within the organisation immediately.

Thirdly, its **calculating cyber security event impact**:

This is really about getting a grip on all eventualities following an attack. Built into this is a clear understanding of how this is dealt with if and when it takes place. In other words, it's really about ensuring everyone is prepared for the eventuality such that when it does happen, nobody falls into a blind manic mode.

Respond

Respond pretty much universally breaks into four categories of action:

1. **Test**
2. **Update**
3. **Act**
4. **Communicate.**

Organisations that are cyber security responsible know exactly what to do in the event of an attack before it takes place. The first duty of Response is therefore to **test** out those actions before they happen. It's a bit like being an actor. Few, if any, actors go on stage or in front of camera, without first rehearsing or learning their lines.

Activity two is about ensuring that testing is current and up to date, whether that means ensuring new staff are fully trained, existing staff remain current, and all systems are **updated**.

Activity three only happens when an attack takes place – to **act**. The job is simply to follow through with everything you have prepared for in the test and update stages.

The final activity is about joining the dots and ensuring that all third parties and key stakeholders are both kept in the loop, and where necessary, part of the solution, through **communication**.

Recovery

An attack has taken place, and the required action has been taken. We then move onto the recovery stage.

This stage is mainly about three things:

1. **Repair and communicate**
2. **Update**
3. **Damage limitation.**

Repair is concerned with getting all assets up and running again with minimal loss of data and downtime. This follows the procedures as laid out in the policy. **Communication** with both the internal and external co-workers involved is a key part of this process.

The **Update** activity is about going back to the recovery plan and ascertaining whether any element of it needs to be revised in the light of the experience. For example, perhaps certain things didn't go according to plan. In which case, what needs to change so that when a next time comes around, the recovery runs smoother.

Finally, there is going to be an element of **damage limitation** in terms of publicity. Depending on the size of the organisation and the sector it is in, this will include regulators, shareholders, customers and suppliers, competitors, and the general public.

Summary

This session should have given you a top-level perspective of what cyber security is and why it is so fundamentally crucial to all areas of society in the digital world.

Before we close, remember the independent learning that forms part of the assessment for this unit. It's a journal activity and what you need to do is undertake some research on the three topics:

- 1. How do different governments manage cyber security within and across their boundaries?**
- 2. Identify and research a recent cyber security attack around the world. Try to understand: What, Why, and How?**
- 3. Revisit the U.K.'s Computer Misuse Act. Explore the recent changes to the Act, and what it means for individuals.**

We suggest up to an hour of research on each topic and then spend twenty minutes distilling what you have taken away from that research onto the page. You may prefer to journal digitally.

Remember the key to journaling is to put down in words your own thoughts and learning. Copying and pasting from a website you've visited to your own journal is not what this is all about. Also, individuals journal in different ways. For some it is about the written word. For others, diagrams and drawings are the preferred mode of communication. This latter approach is fine but remember that assessors will need to be able to comprehend what you are trying to convey. Therefore, abstract drawings with no words attached are unlikely to give the assessor a true understanding of what you have learnt.



British Qualifications
in Skills and Leadership

www.bqsl.org